



TECNOLÓGICA DEL ORIENTE
INSTITUCIÓN DE EDUCACIÓN SUPERIOR
VIGILADA MINEDUCACIÓN



SEGURIDAD EN SOFTWARE



I. DATOS GENERALES

Asignatura:	Seguridad en Software
Nivel:	Pregrado
Duración:	8 semanas
Modalidad:	Virtual
Créditos:	3
Componente:	Profesional
Ciclo:	Profundización
Semestre:	7

II. TABLA DE CONTENIDO

UNIDAD TEMÁTICA	TEMA	SUBTEMAS
I	Conceptos básicos de seguridad	Principios de seguridad informática
		Identificación de vulnerabilidades
		Uso de buenas prácticas
II	Cifrado y autenticación	Algoritmos de cifrado simétrico y asimétrico
		Protocolos de autenticación (OAuth, SAML)
		Manejo de certificados digitales
III	Pruebas de seguridad	Pruebas de penetración
		Herramientas como OWASP ZAP
		Simulación de ataques

III. INTRODUCCIÓN GENERAL DE LA ASIGNATUR

¡Bienvenidos!

Se da la bienvenida a la asignatura **Seguridad de Software**, diseñada para fortalecer la comprensión de los fundamentos necesarios para proteger las aplicaciones frente a riesgos y amenazas comunes. Durante esta experiencia formativa, el estudiante desarrollará habilidades clave en el uso de buenas prácticas, cifrado, autenticación y pruebas de seguridad, con el fin de construir software más robusto y confiable. La participación activa y el compromiso con la calidad serán esenciales para el logro de los objetivos.

- Explicar los principios básicos de seguridad en software, reconociendo los riesgos y vulnerabilidades más frecuentes.
- Aplicar técnicas de cifrado y autenticación para proteger datos y validar identidades en los sistemas.
- Realizar pruebas de seguridad, identificar vulnerabilidades y proponer medidas correctivas.

Estas capacidades son fundamentales para prevenir incidentes, proteger la información y garantizar el funcionamiento seguro de las aplicaciones.

La seguridad es un pilar clave en el desarrollo de software moderno. Una vulnerabilidad puede tener consecuencias críticas como pérdida de datos o accesos no autorizados.

Por ello, este curso proporciona herramientas que permiten diseñar aplicaciones seguras desde el inicio, con el objetivo de minimizar riesgos y asegurar que los productos cumplan con estándares de calidad y protección.



Al finalizar, el estudiante será capaz de:

- Reconocer los fundamentos de seguridad y vulnerabilidades frecuentes en software.
- Emplear cifrado y protocolos como OAuth y SAML para proteger la información.
- Utilizar herramientas como OWASP ZAP para realizar pruebas y detectar puntos débiles en los sistemas.

Estas competencias contribuyen al desarrollo de soluciones digitales confiables y seguras para los usuarios.

El contenido se organiza en tres unidades:

Unidad 1: Conceptos básicos de seguridad

Se abordan los principios de la seguridad informática, como confidencialidad, integridad, disponibilidad y autenticación. También se estudian las vulnerabilidades comunes y el uso de buenas prácticas como la codificación segura y el principio de mínimo privilegio.

Unidad 2: Cifrado y autenticación

El estudiante aprenderá a utilizar algoritmos de cifrado simétrico y asimétrico, y a implementar protocolos de autenticación como OAuth y SAML. Se explicará además el uso de certificados digitales en entornos seguros.

Unidad 3: Pruebas de seguridad

Se presentan metodologías de pruebas de penetración y el uso de herramientas como OWASP ZAP. El estudiante simulará ataques controlados para identificar vulnerabilidades y proponer soluciones.

Esta asignatura promueve una visión crítica y responsable del desarrollo seguro. Cada decisión técnica tomada para proteger una aplicación impacta directamente en la confianza del usuario y la estabilidad del sistema.

Construir software seguro empieza por comprender los riesgos y aplicar buenas prácticas desde el diseño. Con dedicación y criterio, el estudiante podrá liderar proyectos que prioricen la seguridad y aporten valor real en cualquier entorno.

¡Bienvenidos al reto de construir software confiable y protegido!

IV. PROPÓSITO DE FORMACIÓN

Proporcionar conocimientos y habilidades para garantizar la seguridad en el desarrollo de software, identificando vulnerabilidades y aplicando medidas preventivas efectivas.



VER VIDEO

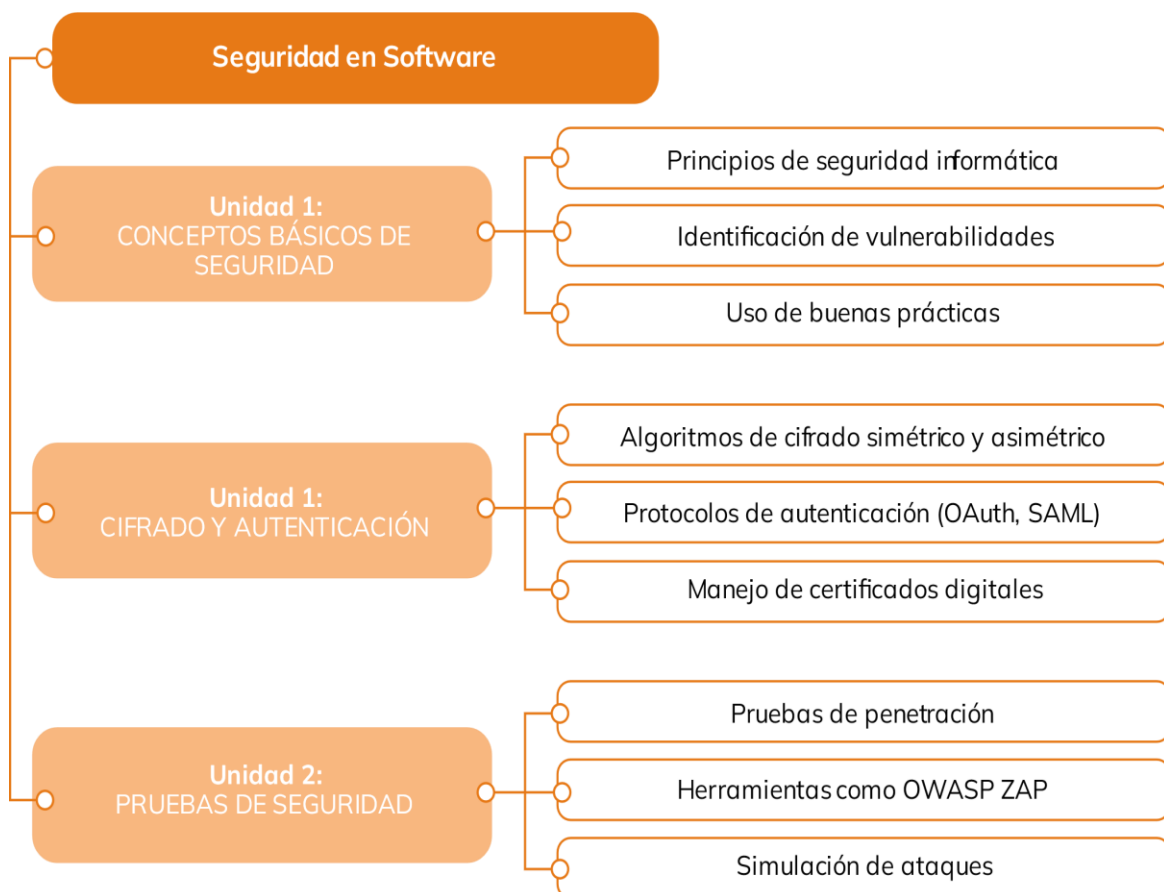




V. RESULTADOS DE APRENDIZAJE

Resultado de aprendizaje 1
Explica los principios básicos de la seguridad en software, identificando los riesgos y vulnerabilidades más comunes en aplicaciones.
Resultado de aprendizaje 2
Aplica técnicas de cifrado y autenticación en el desarrollo de software para proteger los datos y asegurar la identidad de los usuarios en los sistemas.
Resultado de aprendizaje 3
Realiza pruebas de seguridad en aplicaciones, identificando posibles vulnerabilidades y proponiendo medidas correctivas para minimizar riesgos.

VI. SÍNTESIS ASIGNATURA





VII. GLOSARIO

PALABRA, TÉRMINO O ABREVIATURA	SIGNIFICADO
Análisis de resultados	Es el proceso mediante el cual se interpretan los hallazgos obtenidos en una prueba de penetración o simulación de ataque, para identificar fallos críticos y proponer mejoras de seguridad.
Ataque de fuerza bruta	Es una técnica de intrusión que consiste en probar múltiples combinaciones posibles de contraseñas o claves hasta encontrar la correcta para acceder a un sistema.
Autenticación	Proceso mediante el cual un sistema verifica que una persona o entidad es quien dice ser, utilizando credenciales como contraseñas, tokens o certificados digitales.
Autoridad de certificación (CA)	Entidad confiable encargada de emitir, validar y revocar certificados digitales. Actúa como el núcleo de confianza dentro de la Infraestructura de Clave Pública (PKI).
Certificado digital	Archivo electrónico que asocia una clave pública con la identidad de su propietario, garantizando la seguridad en procesos como el cifrado, la firma digital y la autenticación.
Cifrado asimétrico	Método criptográfico que utiliza un par de claves (una pública y una privada) para proteger la información. La clave pública cifra los datos, y la privada los descifra.
Cifrado simétrico	Técnica de cifrado donde se emplea la misma clave para cifrar y descifrar la información. Es más rápido que el cifrado asimétrico, pero requiere una forma segura de compartir la clave.
Clave privada	Clave secreta utilizada en el cifrado asimétrico para descifrar mensajes cifrados con la clave pública o para firmar digitalmente. Debe mantenerse protegida en todo momento.
Clave pública	Clave utilizada para cifrar datos en el esquema de cifrado asimétrico. Está disponible públicamente y se asocia con una clave privada correspondiente.
Confidencialidad	Principio de seguridad que asegura que la información solo sea accesible para las personas autorizadas y se mantenga protegida contra accesos no autorizados.
Disponibilidad	Garantía de que los sistemas, datos y servicios estén accesibles y operativos cuando los usuarios legítimos los requieran.
Escaneo de vulnerabilidades	Es la acción de analizar una aplicación o sistema en busca de debilidades conocidas, utilizando herramientas automatizadas como OWASP ZAP para identificar posibles puntos de entrada.
Fase de explotación	Es una etapa dentro de una prueba de penetración en la que el atacante intenta aprovechar vulnerabilidades descubiertas para acceder a información o sistemas de manera no autorizada.
Fase de reconocimiento	Es la etapa inicial de una prueba de penetración o simulación de ataque, en la cual se recopila información sobre el objetivo (red, servidores, dominios) sin interactuar directamente con él.
Firma digital	Técnica criptográfica que garantiza que un mensaje o documento no ha sido alterado y que proviene de una fuente legítima. Se basa en el uso de claves públicas y privadas.



Herramientas de <i>pentesting</i>	Son soluciones de software especializadas que permiten ejecutar ataques simulados, escanear vulnerabilidades y analizar la seguridad de sistemas informáticos. OWASP ZAP es una de las más representativas.
Inyección SQL	Es un tipo de ataque que aprovecha una vulnerabilidad en la validación de entradas de bases de datos, permitiendo ejecutar comandos SQL maliciosos en el sistema de la víctima.
Integridad	Propiedad que asegura que los datos y sistemas no han sido alterados de manera no autorizada, manteniendo su exactitud y confiabilidad.
Mínimo privilegio	Principio de seguridad que establece que cada usuario o proceso debe tener solo los permisos estrictamente necesarios para realizar sus tareas.
OAuth 2.0	Protocolo de autorización que permite a aplicaciones acceder a recursos protegidos en nombre del usuario sin necesidad de compartir contraseñas directamente.
OpenID Connect	Extensión del protocolo OAuth 2.0 que añade funciones de autenticación de usuarios. Permite a las aplicaciones confirmar la identidad de manera segura y estandarizada.
OWASP ZAP	Es una herramienta de seguridad de código abierto desarrollada por OWASP, diseñada para realizar escaneos de vulnerabilidades y análisis de seguridad en aplicaciones web de forma automatizada o manual.
<i>Pentesting</i>	Es una técnica profesional para evaluar la seguridad de un sistema informático mediante la simulación de ataques controlados con el fin de identificar vulnerabilidades explotables.
<i>Phishing</i> simulado	Es una práctica en la que se imitan ataques de suplantación de identidad para entrenar a usuarios en la identificación de correos y sitios fraudulentos, evaluando su nivel de conciencia en ciberseguridad.
PKI (Infraestructura de Clave Pública)	Conjunto de tecnologías, políticas y procedimientos para gestionar certificados digitales y claves criptográficas, facilitando comunicaciones seguras.
Principios de codificación segura	Conjunto de normas y prácticas recomendadas para escribir código que minimice vulnerabilidades y errores de seguridad.
Principios de seguridad informática	Conjunto de conceptos fundamentales que guían la protección de la información, incluyendo confidencialidad, integridad, disponibilidad, autenticación, entre otros.
Rebase	Técnica en control de versiones que permite reorganizar y aplicar commits sobre otra base, como alternativa a la fusión para evitar conflictos.
SAML (<i>Security Assertion Markup Language</i>)	Estándar basado en XML utilizado para intercambiar información de autenticación y autorización entre diferentes sistemas de manera segura.
Simulación de ataques	Es el proceso de ejecutar amenazas controladas contra sistemas informáticos, con el objetivo de medir su capacidad de respuesta y robustez ante intentos de intrusión reales.
Trazabilidad	Capacidad de rastrear el origen y los cambios realizados en un sistema o dato, facilitando la auditoría y el análisis de eventos.
Vulnerabilidad	Debilidad o falla en un sistema, aplicación o proceso que puede ser explotada para comprometer su seguridad.



XSS (<i>Cross-site scripting</i>)	Es un tipo de vulnerabilidad común en aplicaciones web que permite a un atacante inyectar scripts maliciosos en el navegador de otro usuario, comprometiendo datos o sesiones activas.
-------------------------------------	--

VIII. EVALUACIÓN

	Actividad de aprendizaje	Nombre de la Actividad	Porcentaje evaluativo
Semana 1	Quiz Diagnóstico	Cuestionario evaluativo inicial	0 %
Semana 1	AA1(unid 1)	AA1. Foro de Discusión: Principios de Seguridad Informática	5 %
Semana 2	AA2 (unid 1)	AA2. Taller: Mapa Mental sobre Vulnerabilidades de Software	15 %
Semana 3	AA1(unid 2)	AA1. Actividad: Elaboración de un Mapa Conceptual sobre Algoritmos de Cifrado Simétrico y Asimétrico	5 %
Semana 4	AA2 (unid 2)	AA2: Taller Grupal – Implementación de Certificados Digitales en una Aplicación Web	20 %
Semana 5	AA1(unid 3)	AA1: Estudio de Caso - Simulación de Ataques en un Proyecto de Software	5 %
Semana 6	AA2 (unid 3)	AA2 - ABP: Proyecto Integrador: Evaluación de Seguridad con OWASP ZAP	20 %
Semana 7	Examen final	Cuestionario evaluativo final	30 %
Semana 8	CIERRE DEL CURSO		
TOTAL, EVALUACIÓN			100 %

IX. BIBLIOGRAFÍA

RECURSOS BIBLIOGRÁFICOS DE REVISIÓN BÁSICA		BASES DE DATOS
U1	Escrivá Gascó, G. (2013). <i>Seguridad informática</i> : (ed.). Macmillan Iberia, S.A. https://elibro.net/es/lc/tecnologicadeloriente/titulos/43260	E-libro
U1	Costas Santos, J. (2015). <i>Seguridad informática</i> : (ed.). RA-MA Editorial. https://elibro.net/es/lc/tecnologicadeloriente/titulos/62452	E-libro
U1	Gómez Vieites, Á. (2015). <i>Auditoría de seguridad informática</i> : (ed.). RA-MA Editorial. https://elibro.net/es/lc/tecnologicadeloriente/titulos/62464	E-libro
U1	Gómez Vieites, Á. (2014). <i>Enciclopedia de la seguridad informática</i> : (2 ed.). RA-MA Editorial. https://elibro.net/es/lc/tecnologicadeloriente/titulos/106416	E-libro
U1	Omaña, M. (2012). <i>Manufactura esbelta: una contribución para el desarrollo de software con calidad</i> : (ed.). Red Enlace. https://elibro.net/es/lc/tecnologicadeloriente/titulos/98547	E-libro



U1	Giménez Albacete, J. F. (2023). Seguridad en equipos informáticos. IFCT0109: (2 ed.). IC Editorial. https://elibro.net/es/lc/tecnologicadeloriente/titulos/232697	E-libro
U1	Universidad Pontificia Comillas. (s.f.). <i>Confidencialidad, integridad y disponibilidad</i> [Imagen]. Ciberseguridad Comillas. https://ciberseguridad.comillas.edu/confidentiality-integrity-and-availability/	https://ciberseguridad.comillas.edu/
U1	OWASP Foundation. (s.f.). <i>OWASP Mobile Top 10</i> . [Imagen]. OWASP. https://owasp.org/www-project-mobile-top-10/	https://owasp.org/
U1	Lozano, L., & Barrientos, J. (2023). [Imagen]. <i>Ciclo de vida de Desarrollo Seguro de Software</i> . En ResearchGate. https://www.researchgate.net/figure/Figura-3-Ciclo-de-vida-de-Desarrollo-Seguro-de-Software_fig3_366369323	https://www.researchgate.net/
U1	Fortinet. (s.f.). <i>¿Qué es una vulnerabilidad común y expuesta (CVE)?</i> . Fortinet. https://www.fortinet.com/lat/resources/cyberglossary/cve	https://www.fortinet.com/
U2	Ortega Candel, J. M. (2018). <i>Seguridad en aplicaciones Web Java</i> : (ed.). RA-MA Editorial. https://elibro.net/es/lc/tecnologicadeloriente/titulos/106511	eLibro
U2	Hernández Encinas, L. (2016). <i>La criptografía</i> : (ed.). Editorial CSIC Consejo Superior de Investigaciones Científicas. https://elibro.net/es/lc/tecnologicadeloriente/titulos/41843	eLibro
U2	Costas Santos, J. (2015). <i>Seguridad y alta disponibilidad</i> : (ed.). RA-MA Editorial. https://elibro.net/es/lc/tecnologicadeloriente/titulos/62477	eLibro
U2	González Manzano, L. & De Fuentes García-Romero de Tejada, J. M. (2023). <i>Sistemas seguros de acceso y transmisión de datos</i> . IFCT0109: (2 ed.). IC Editorial. https://elibro.net/es/lc/tecnologicadeloriente/titulos/232694	eLibro
U2	Gómez Vieites, Á. (2015). <i>Sistemas seguros de acceso y transmisión de datos</i> : (ed.). RA-MA Editorial. https://elibro.net/es/lc/tecnologicadeloriente/titulos/62465	eLibro
U2	González Manzano, L. & De Fuentes García-Romero de Tejada, J. M. (2023). <i>Sistemas seguros de acceso y transmisión de datos</i> . IFCT0109: (2 ed.). IC Editorial. https://elibro.net/es/lc/tecnologicadeloriente/titulos/232694	eLibro
U3	Gómez Vieites, Á. (2015). <i>Auditoría de seguridad informática</i> : (ed.). RA-MA Editorial. https://elibro.net/es/lc/tecnologicadeloriente/titulos/62464	eLibro
U3	Weidman, G. (2014). <i>Penetration Testing: A Hands-On Guide to Hacking</i> . Internet Archive. https://archive.org/details/penetration-testing-a-hands-on-guide-to-hacking	archive
U3	Ortega Candel, J. M. (2018). <i>Seguridad en aplicaciones Web Java</i> : (ed.). RA-MA Editorial. https://elibro.net/es/lc/tecnologicadeloriente/titulos/106511	eLibro
U3	OWASP Foundation. (2018). <i>ZAP 2.9 Getting Started Guide</i> . Open Web Application Security Project. https://www.zaproxy.org/pdf/ZAPGettingStartedGuide-2.9.pdf	zaproxy



U3	Gómez Vieites, Á. (2014). Enciclopedia de la seguridad informática: (2 ed.). RA-MA Editorial. https://elibro.net/es/lc/tecnologicadeloriente/titulos/106416	eLibro
U3	Chicano Tejada, E. (2023). Auditoría de seguridad informática. IFCT0109: (2 ed.). IC Editorial. https://elibro.net/es/lc/tecnologicadeloriente/titulos/232692	eLibro

X. RECURSOS EDUCATIVOS DIGITALES

RECURSOS BIBLIOGRÁFICOS DE REVISIÓN COMPLEMENTARIA		BASES DE DATOS
1	Baca Urbina, G. (2016). <i>Introducción a la seguridad informática</i> (ed.). Grupo Editorial Patria. https://elibro.net/es/lc/tecnologicadeloriente/titulos/40458	eLibro
2	Chicano Tejada, E. (2015). <i>Gestión de incidentes de seguridad informática (MF0488_3)</i> (ed.). IC Editorial. https://elibro.net/es/lc/tecnologicadeloriente/titulos/44101	eLibro
3	Echeverri, J., Aristizábal, M., & González, L. (2013). <i>Reflexiones sobre ingeniería de requisitos y pruebas de software</i> (ed.). Corporación Universitaria Remington. https://elibro.net/es/lc/tecnologicadeloriente/titulos/68913	eLibro
4	Escrivá Gascó, G. (2013). <i>Seguridad informática</i> (ed.). Macmillan Iberia, S.A. https://elibro.net/es/lc/tecnologicadeloriente/titulos/43260	eLibro
5	Guillamón Morales, A. (2013). <i>Manual desarrollo de elementos software para gestión de sistemas</i> (ed.). Editorial CEP, S.L. https://elibro.net/es/lc/tecnologicadeloriente/titulos/50603	eLibro
6	Kim-Park, D. S. (2011). <i>Aplicación de un oráculo de prueba automatizado a la evaluación de salidas de programas basados en XML</i> . Revista Española de Innovación, Calidad e Ingeniería del Software, 7(1), 6–21. Asociación de Técnicos de Informática (ATI). https://elibro.net/es/lc/tecnologicadeloriente/titulos/26203	eLibro
7	Ortega Candel, J. M. (2018). <i>Seguridad en aplicaciones Web Java</i> (ed.). RA-MA Editorial. https://elibro.net/es/lc/tecnologicadeloriente/titulos/106511	eLibro
RECURSOS AUDIOVISUALES		
1	Rivera, R. (2019, 24 de octubre). <i>Principios de la Seguridad de la Información</i> . [Vídeo]. YouTube. https://www.youtube.com/watch?v=WRT1J2rLXd4	



2	AlbertoLopez Teach Tips (2023, 23 de enero) ¿Qué es un PAYLOAD, un EXPLOIT y una VULNERABILIDAD en CIBERSEGURIDAD? Diferencias Alberto López [video] YouTube. https://youtu.be/yXhAbwx9liU?si=UPjGH9XtGPCqftKE
3	Ministerio TIC Colombia. (2013, 1 de febrero). Ricardo Suárez - Principios de Programación Segura. [Video]. YouTube. https://www.youtube.com/watch?v=8-3FZ4Opn4U
4	AlbertoLopez TECH TIPS. [@AlbertoLopezVLOG] (2020, 2 de diciembre). Cifrado SIMÉTRICO y ASIMÉTRICO 5 DIFERENCIAS Seguridad de la información. [Video]. YouTube. https://www.youtube.com/watch?v=5BYhdr5n3es
5	OpenWebinars. [@openwebinarsnet] (2019, 16 de diciembre). QUÉ ES OAUTH 2. [Video]. YouTube. https://www.youtube.com/watch?v=GeXbsMezi8s&t=30s
6	Unidad de Innovación UMU. [@UnidadInnova] (2013, 30 de enero). Certificados digitales Parte 1. [Video]. YouTube. https://www.youtube.com/watch?v=ry2i9dXonxU
7	return(GiS). (2023, 13 de diciembre). [Video]. YouTube. https://www.youtube.com/watch?v=OnJBubBGadQ
8	Walker, M. (2020, 9 de junio). Pruebas de seguridad de aplicaciones con OWASP ZAP. [Video]. YouTube. https://www.youtube.com/watch?v=ZkjeQVv84KA
9	solomongo CIBERSEGURIDAD. (2025, 22 de mayo). #DVWA#damn #vulnerable #web #application #sqlinjection #csrf #XSS #site #hacking #simulador. [Video]. YouTube. https://www.youtube.com/watch?v=rfoEAd4W2G0
PÁGINAS WEB DE REVISIÓN BÁSICA	
1	Universidad San Marcos. (s.f.). ¿Cuáles son los principios de la seguridad informática? https://www.usanmarcos.ac.cr/blogs/cuales-son-los-principios-de-la-seguridad-informatica
2	InfoProtección. (21 de Marzo del 2025). Vulnerabilidades de software: cómo identificarlas y reducir riesgos. https://www.infoproteccion.com/ciberseguridad/vulnerabilidades-software-como-identificarlas/
3	Hacking Ético Blog. (30 de septiembre del 2024). Las 10 mejores prácticas de seguridad informática que todo profesional debe conocer. https://hackingeticoblog.com/las-10-mejores-practicas-de-seguridad-informatica-que-todo-profesional-debe-conocer/
4	RedesZone. (2021, 24 mayo). Criptografía: Algoritmos de clave simétrica y asimétrica explicados. RedesZone. https://www.redeszone.net/tutoriales/seguridad/criptografia-algoritmos-clave-simetrica-asimetrica/
5	Keeper Security. (2024, 13 de noviembre). ¿Cuál es la diferencia entre SAML y OAuth? Keeper Security. https://www.keepersecurity.com/blog/es/2024/11/13/saml-vs-oauth-whats-the-difference/
6	Scalefusion. (2024, 24 de junio). ¿Qué son los certificados digitales y cómo mejoran la gestión de dispositivos? Scalefusion Blog. https://blog.scalefusion.com/es/gesti%C3%B3n-de-certificados-digitales/
7	Rootstack. (2022, 25 julio). Las 5 mejores herramientas de pruebas de penetración. Rootstack. https://rootstack.com/es/blog/pruebas-de-penetracion-herramientas
8	Seguridad Informática Actual. (2022, 29 de noviembre). Tutorial OWASP ZAP – Revisión completa de esta herramienta. https://seguridadinformaticaactual.com/2022/11/29/tutorial-owasp-zap-revision-completa-de-esta-herramienta/
9	Ciberseguridad Blog. (2022, octubre 3). Simulacros de ciberataques: Preparando a las organizaciones. https://ciber-seguridad.blog/simulacros-de-ciberataques